INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Incident Response Planning Assignment

GRC205 Incident Management and Business Continuity – Week 20 | Northbridge Skills Institute (fictional)

Item	Detail
Assessment	GRC205 Incident Response Planning Assignment (Week 20) – 100 marks, 20% of course grade
Student name	Francisca Umejesi
Student ID	2025/GCR/12816
Official email	[ENTER OFFICIAL ICDFA EMAIL]
Role adopted	Incident Response Lead, Northbridge Skills Institute (fictional)
Word count	11,384 words (body text and tables, excluding the reference list)
Filename	GRC205_IRP_Assignment_2025_GCR_12816.docx

How to read this report

Every claim about the incident is labelled so that the reader can see what is known and what is not. **Confirmed** means directly observed in the evidence pack (E01–E08). **Hypothesis** means a reasoned working explanation that still needs testing. **Unresolved** means an open question with a named check. **Assumption** (A1–A10, below) means a fact I have supplied because the brief is silent; each is labelled where it is used. All names, contact details and times are fictional. All evidence collection is described as **planned**; nothing in this report claims that an acquisition was performed or that a hash value exists. The report is organised by the four teaching stages (preparation; detection and analysis; containment, eradication and recovery; post-incident activity) (ICDFA, n.d., slide 6). Where NIST SP 800-61 Revision 3 is cited, it is used only for its CSF 2.0 alignment, not for the four-stage model (NIST, 2025).

Assumptions register

ID	Assumption (not in the brief)	Used in
A1	Northbridge is a data controller operating in Nigeria, so the Nigeria Data Protection Act 2023 is the working legal reference. Legal counsel must confirm this and check any contractual or foreign-learner duties.	Task 4
A2	The Incident Response Lead (me) holds pre-delegated authority to isolate systems without waiting for executive sign-off, with the Executive Sponsor informed within 15 minutes.	Tasks 2, 3
A3	An external digital forensics and incident response (DFIR) provider can be engaged within about two hours, whether through a retainer or an emergency call-out. No retainer exists today.	Tasks 2, 3
A4	The finance officer is a victim, not a malicious insider. This is a working position, tested by interview, and it does not imply fault.	Task 1
A5	Learner mobile numbers can be reached from a source outside FS01 (for example the M365 directory or a student-record export). This must be verified in the first hour.	Tasks 3, 4
A6	The online examination uses LMS01 for delivery and stores submissions on FS01, as the brief states that the portal depends on FS01 files.	Tasks 1, 3
A7	The Friday 17:00 disconnected backup predates the intrusion, because the earliest known event is E01 on Sunday 16:40. Dwell time before E01 is unknown, so this is validated before use.	Task 3
A8	Staff mobile phone numbers are held personally by the IT team and management, so the phone tree can start immediately (E08 confirms phones work).	Task 3
A9	The business accepts re-sitting or re-submitting work created after Friday 17:00 if the Friday disconnected backup is the only trustworthy source.	Task 3
A10	Exercise minute 0 equals 08:45 WAT on Day 0, and exercise minutes map to scenario clock time one-to-one.	Task 5

Task 1 – Incident classification and initial assessment (15 marks)

Stage: Detection and Analysis (ICDFA, n.d., slides 9–10). Clock: 08:45 WAT, Monday, Day 0, when I take control. The 11:00 examination for 100 learners is 2 hours 15 minutes away.

1.1 Evidence-linked timeline

Table 1. Timeline of E01–E08 separating what is confirmed from what is hypothesised and unresolved. Times are WAT.

Time	ID	Confirmed observation	Working hypothesis	Unresolved question
Fri, Day −3 17:00	Brief	Last disconnected backup completed. Network backups are not immutable. No restoration test on either route in 90 days.	Predates the intrusion (A7).	Is it complete and restorable?
Sun, Day −1 16:40	E01	Finance officer reports opening an unexpected payroll attachment on FIN-PC07 (user report and mail record).	Phishing attachment was the initial access vector.	Did the code execute? What was the file? Which sender and which other recipients?
Mon, Day 0 01:15	E02	M365 audit shows a sign-in to the finance officer account from an unfamiliar IP and new device.	Credentials or session token stolen after E01.	Was MFA used, bypassed or absent? Was it the user?
01:35	E03	svc_backup made remote administrator logons to FS01 and BAK01 outside its usual schedule.	Attacker used svc_backup to move laterally and reach the backups.	Reason? Source host or IP? Was it a change or maintenance task?
01:50	E04	Proxy shows FIN-PC07 uploaded 1.2 GB over HTTPS to unfamiliar cloud storage.	Possible staging and exfiltration of data before encryption.	What was in the 1.2 GB? Did it contain personal data? Was it a legitimate sync?
02:00	E05	Backup console shows FS01 and LMS01 jobs as successful.	Jobs ran, but the data may be encrypted, tampered or already compromised.	Is the backup readable and clean? Can BAK01 be trusted after E03?
08:30	E06	EDR and helpdesk report mass file changes on FIN-PC07. FS01 shares contain .locked files and a ransom note.	Ransomware encryption is active or has just completed. Family unknown.	Which family? When did encryption start on FS01? Other hosts affected?
08:40	E07	Portal login page loads, but learners cannot open materials or submit assessments.	LMS01 is degraded because it depends on FS01 files (A6), not necessarily itself compromised.	Is LMS01 itself encrypted, altered or clean?
08:45	E08	Incident contact list on FS01 is inaccessible. Staff phones work.	The list was encrypted with the share.	Is corporate email trustworthy? Are attacker rules or forwarding in place?

Reading across the timeline. E02–E05 fall inside a 45-minute window (01:15–02:00) in the middle of the night, and E06 follows about six and a half hours later. That pattern is consistent with a staged attack (access, privilege use, data staging, backup interference, then encryption), but it is a **hypothesis**. I have no evidence for the 02:00–08:30 interval, which is a visibility gap to be closed from log retention.

Plausible alternative explanations for ambiguous events

Event	Leading hypothesis	Alternative explanation	Check that separates them
E02 – unfamiliar sign-in	Attacker with stolen credentials or an adversary-in-the-middle session token.	(a) The officer legitimately signed in from a new phone or network, for example while travelling or on mobile data. (b) A password-spray or sign-in attempt that failed MFA and never succeeded.	Sign-in log result codes, MFA method used, token issuance, device ID, and a short interview with the officer.
E03 – svc_backup logons	Attacker reused the service account to reach FS01 and BAK01.	(a) A scheduled change, patch or vendor maintenance job ran off-schedule. (b) A backup job re-run after a failed run.	Source IP and logon type in Windows Security events, change tickets, and IT team confirmation.
E04 – 1.2 GB upload	Exfiltration of finance or learner data.	(a) A legitimate cloud sync or personal backup of large files. (b) Malware beaconing or tool download with little sensitive content.	Destination ownership, full proxy URL and SNI, EDR file-read telemetry, FS01 file-access audit, and timing against E02.
E05 – backup success	Backups are usable.	Jobs report success even when they back up already-encrypted or tampered data. Success means the job ran, not that the data is recoverable.	Test restore into an isolated environment, and compare file hashes and entropy against known-good data.

1.2 Incident classification and severity

Classification. Ransomware (encryption with extortion note), with **suspected** data exfiltration (double extortion), **suspected** compromise of one user account and one privileged service account, and **suspected** interference with backups. Initial attack vector: phishing attachment (**hypothesis**, E01). Attribution to any named group is not established, and I will not assert it. The slide deck rates ransomware as Critical (ICDFA, n.d., slide 4).

Table 2. Severity criteria used in this plan (adapted from the Critical, High and Medium/Low tiers on slide 10; I added the Low tier).

Level	Criteria (any one is enough unless stated)	Response expected
Critical	Confirmed or likely loss of availability or integrity of a critical service or data set with a hard deadline; or likely exposure of personal data; or doubt about the integrity of the recovery source; or active spread to new systems.	Immediate full CSIRT activation. Executive notified within 15 minutes. Legal and privacy advice engaged. External DFIR engaged.
High	Confirmed compromise of one non-critical system or a single account, no sign of data exposure, backups verified safe, impact contained within hours.	Rapid response within SLA. Management notified. Core CSIRT on call.
Medium	Malware or policy violation on a single endpoint, contained, no sensitive data involved, no service impact beyond that user.	Standard workflow, ticketed and tracked.
Low	Blocked or failed attempt, or a suspicious event with no evidence of compromise.	Logged and monitored. Reviewed in routine meeting.

Selected level: CRITICAL (provisional), declared at 08:45. Justification:

- **Operational impact (confirmed).** Encryption on FIN-PC07 and FS01 (E06) and learner access to materials and submissions failing (E07). A 100-learner examination starts in 2 hours 15 minutes, and the contact list is unavailable (E08).
- **Affected data (potential).** FS01 holds data that the brief says the institute keeps (learner contact details, admission documents, assessment records, finance files). A 1.2 GB upload (E04) and the ransom note make exfiltration plausible, but it is **unproven**.
- **Uncertainty.** An off-schedule privileged account (E03) and unverified backups (E05) mean the recovery source may be compromised. I rate on the **credible worst case** until evidence reduces it, as the response cost of over-rating for a few hours is far lower than that of under-rating.
- **What would lower or raise the rating.** I would move to High if: encryption is confirmed limited to FIN-PC07 and FS01, LMS01 is verified clean, BAK01 and the Friday backup are verified untouched, and logs show E04 was not personal data. The rating stays Critical, and the regulator and notification workstream escalates, if personal data exfiltration is confirmed or backups are found tampered.

1.3 Affected assets and CIA impact

Table 3. Assets, status and separate confidentiality, integrity and availability (C, I, A) assessment. Status key: Confirmed = affected per evidence; Potential = at risk but unproven.

Asset	Status (evidence)	Confidentiality	Integrity	Availability
FIN-PC07 finance workstation	Confirmed – E01, E04, E06	High risk: payroll and finance data, 1.2 GB upload (E04).	Compromised: mass file changes (E06).	Lost for the officer.
FS01 shared file server	Confirmed – E06	Possible: privileged access seen (E03).	Compromised: .locked files and ransom note.	Lost for all users and for LMS01 content.
LMS01 learning portal	Potential – E07	Unknown. Content and learner records may be exposed.	Unknown. Needs file-integrity check.	Degraded: login loads but materials and submissions fail.
BAK01 backup repository	Potential – E03, E05	Possible: holds copies of all data.	Not trusted until verified; may be altered or deleted.	Unknown. Online and not immutable.
Finance officer M365 account / mailbox	Potential – E01, E02	High risk: mail, OneDrive and shared data.	Possible rule or forwarding changes.	Available to attacker, to be disabled.
svc_backup account	Potential – E03	Admin access to FS01 and BAK01.	Used outside its schedule.	Must be disabled, which may stop backups.

Asset	Status (evidence)	Confidentiality	Integrity	Availability
Incident contact list	Confirmed – E08	n/a	n/a	Lost: it was on the encrypted server.
Examination service (100 learners, 11:00)	Confirmed at risk – E07	Assessment content and answers may be exposed.	Risk of corrupted or untrusted results.	At risk of failing to run.

Response priorities (in order)

1. **Stop spread and protect recovery options.** Isolate FIN-PC07 and FS01, suspend svc_backup, and cut BAK01 off the network. Justification: E03 and E05 mean the backups are the asset the attacker most likely wants to deny me.
2. **Preserve evidence while containing.** Capture volatile data and logs before they are lost, and record every action with a timestamp (ICDFA, n.d., slide 11: preserve forensic evidence before changes are made).
3. **Contain the identity layer.** Revoke sessions and reset the finance account, because the attacker may still have M365 access (E02).
4. **Decide the examination by 10:00.** Give a go/no-go decision with enough time to tell learners, and do not reopen the portal on unverified storage.
5. **Establish out-of-band communication.** Use phones (E08) while email trust is unverified.
6. **Scope and validate.** Find the entry point and exfiltration, and validate a backup before any restoration.

1.4 Priority investigation questions

Table 4. Priority investigation questions, resolving checks, and how findings would change severity or scope.

#	Question	Resolving check (planned)	Finding that changes severity or scope
Q1	Did the attachment execute on FIN-PC07, and is the finance account compromised (E01, E02)?	Message trace and headers for the payroll email. EDR process tree on FIN-PC07. M365 sign-in logs (result, MFA, device, token). Interview the officer.	If the account is compromised, then M365 mail, OneDrive and SharePoint enter scope and email is untrusted (affects all communications). If the sign-in was the user, the scope narrows to the endpoint.
Q2	Was svc_backup misused, and has BAK01 or its backup data been altered or deleted (E03, E05)?	Windows Security events (logon type, source IP) on FS01 and BAK01. Change tickets. Interview IT. BAK01 job catalogue, retention and deletion logs. Test restore in isolation.	If tampering is found, the recovery source becomes the Friday disconnected backup, recovery time lengthens and data loss rises. If benign, restoration from network backup may be faster.
Q3	What was in the 1.2 GB upload, and did it include personal data (E04)?	Full proxy log (URL, SNI, bytes). DNS and firewall flow records. EDR file-read telemetry. FS01 file-access audit. Cloud provider ownership lookup.	Personal data confirmed means formal notification workstream starts at once (Task 4) and the learners are informed. A legitimate sync would lower this risk.
Q4	Is LMS01 itself compromised, or only starved of FS01 files (E07)?	Read-only snapshot of LMS01. File integrity comparison against vendor package. Application and web logs. Manual malware scan, since server EDR is incomplete.	If clean, a controlled restore of FS01 content could allow a limited portal return. If compromised, the portal cannot return until rebuilt.
Q5	Has the attacker reached other systems or established persistence beyond FIN-PC07 and FS01?	EDR indicator sweep on all workstations. Manual triage of servers. M365 inbox rules, OAuth app consents and registered MFA methods. Scheduled tasks and new local admins.	Additional hosts or persistence expand eradication scope and delay any restoration approval.

Task 2 – Incident response plan and team responsibilities (20 marks)

Stage: Preparation. The plan follows the core components on slide 14 (mission and structure; roles and escalation; communication protocols; resource requirements) (ICDFA, n.d., slide 14). NIST SP 800-61 Revision 3 frames incident response as part of wider cyber risk management, where Govern, Identify and Protect support preparation and Detect, Respond and Recover make up incident response (NIST, 2025). Table 5 maps the two views so the reader can see where each part of my plan sits.

Table 5. Mapping of the teaching stages to CSF 2.0 functions as used in NIST (2025). The mapping is my own reading, not a NIST statement.

Teaching stage (ICDFA, n.d., slide 6)	CSF 2.0 function (NIST, 2025)	Where it appears in this report
1. Preparation	Govern, Identify, Protect (supporting)	Task 2 policy, CSIRT, RACI, readiness checklist
2. Detection and analysis	Detect, with Identify for asset knowledge	Task 1; Task 3 investigation steps
3. Containment, eradication and recovery	Respond and Recover	Task 3 playbook and acceptance criteria; Task 4 communications
4. Post-incident activity	Improvement feeds all functions	Task 5 improvement plan and review; Task 6

2.1 Incident response policy and plan outline

Table 6. Policy and plan outline for Northbridge Skills Institute.

Element	Policy and plan content
Mission	Protect learners, learner data and the institute's ability to teach and assess by detecting, containing and recovering from security incidents quickly, lawfully and with evidence that stands up to scrutiny.
Objectives	(1) Declare and classify within 15 minutes of credible report. (2) Contain active spread within 30 minutes. (3) Preserve evidence for every containment step. (4) Keep stakeholders informed on a published cycle. (5) Restore only validated systems, approved by the business owner. (6) Complete a blame-free review within 14 days of closure (ICDFA, n.d., slide 12).
Scope	All Northbridge information assets: FIN-PC07 and other endpoints, FS01, LMS01, BAK01, Microsoft 365 identity and email, third-party services and personal data of learners and staff. Applies to staff, contractors and providers with access.
Incident declaration	Any staff member may report. The Incident Response Lead (IRL) declares an incident when there is credible evidence of compromise of confidentiality, integrity or availability (ICDFA, n.d., slide 4). Severity (Table 2) is assigned at declaration and reviewed at least every 2 hours.
Activation and escalation	Critical: IRL activates the full CSIRT by phone tree and informs the Executive Sponsor within 15 minutes. High: core CSIRT and management informed. Medium and Low: ticketed. Automatic Critical triggers: ransomware, privileged-account misuse with data staging, doubt about backup integrity, or suspected personal data exposure. Escalate to external DFIR if containment is not confirmed within 60 minutes.
Authority to isolate	The IRL (deputy: IT Operations Lead) may isolate any endpoint, server, account or network segment without prior approval where there is active harm (A2). The Executive Sponsor is informed within 15 minutes. Decisions are logged with time, reason and expected business impact. Restoring service requires business owner approval, not IRL approval alone.
Documentation	A single incident log (time, actor, action, reason) kept by the Scribe, on paper or an offline device until corporate tools are trusted. Evidence register and chain-of-custody forms. Decision log. Notification record with timestamps. Impact assessment (operational, financial, reputational) (ICDFA, n.d., slide 13).
Review	Plan reviewed annually and after every Critical or High incident, and after every tabletop. Contact list verified monthly. Backup restoration tested quarterly. Version control and sign-off by the Executive Sponsor.

Connection to business continuity. This plan and the business continuity plan (BCP) share the same trigger and decision gate. A Critical incident also invokes the continuity decision on the examination (Task 3, Decision 2). The BCP supplies the business impact analysis inputs that the IR plan uses for recovery order and targets: recovery time objectives (RTO), recovery point objectives (RPO) and manual workarounds (for example a rescheduled or paper-based examination) (ICDFA, n.d., slide 18). IR decides what is safe, and BCP decides how the institute operates in the meantime. The business owner approves service return.

2.2 CSIRT structure

Table 7. CSIRT roles. Role holders are fictional placeholders. Core members are on-call for Critical incidents.

Role (abbreviation)	Held by (fictional)	Main responsibilities
Incident Response Lead / Incident Commander (IRL)	Francisca Umejesi (this plan's author)	Declares and classifies, leads operations, holds isolation authority, makes critical decisions, briefs executives (ICDFA, n.d., slide 15).
Security Analyst (SA)	Institute security analyst (1 post)	Triage, log analysis, EDR hunting, indicator sweeps, containment actions.

Role (abbreviation)	Held by (fictional)	Main responsibilities
Forensics Lead (FOR)	External DFIR provider (A3), with the SA as first-responder until arrival	Evidence acquisition, integrity and custody, malware analysis, supports legal proceedings.
IT Operations Lead (ITO)	Senior IT staff member (1 of 3)	Network isolation, account resets, rebuilds, restores, backup validation.
Business Owner / Academic Registrar (BO)	Head of Examinations	Owns the examination and service priorities, approves restoration and return to service.
Legal and Privacy Adviser (LEG)	External counsel and the institute's data protection officer	Notification obligations, privilege, regulator and law enforcement liaison, ransom-payment legal advice.
Communications Lead (COM)	Marketing and Communications Manager	Stakeholder notices, media holding statements, social media monitoring (ICDFA, n.d., slide 15).
Executive Sponsor (EXEC)	Director of the Institute	Accountable for risk acceptance, regulatory decisions, budget and external engagements.
Scribe and Evidence Custodian (SCR)	Administrative officer, trained	Keeps the incident log, decision log and evidence register. Holds the evidence store key.

Getting extra support with a small team. Northbridge has three IT staff and one security analyst, so surge capacity must come from outside. (1) An external DFIR retainer or emergency call-out agreement, assumed reachable in about two hours (A3), recommended as a readiness action. (2) The Microsoft 365 provider's support channel for tenant-level investigation. (3) The backup, network and ISP providers named on the printed contact card. (4) The national CERT and law enforcement, as advised by legal counsel. (5) Business staff trained as runners and note-takers so technical staff stay on technical work. Escalation to external help is automatic if containment is not confirmed within 60 minutes or if Critical severity persists for 4 hours.

2.3 RACI matrix

R = Responsible (does the work), A = Accountable (single owner who answers for the outcome and approves), C = Consulted (two-way input before action), I = Informed (told after) (ICDFA, n.d., slide 15). A/R means one role is both. Each row has **exactly one A** and at least one R.

Table 8. RACI matrix for ten activities. A dash means not involved.

Activity	IRL	SA	FOR	ITO	BO	LEG	COM	EXEC	SCR
Detection and triage	A	R	I	R	–	–	–	I	–
Analysis and scoping	A	R	R	C	C	C	I	I	I
Containment and isolation	A/R	R	C	R	C	I	I	I	I
Evidence handling and custody	A	R	R	R	–	C	–	–	R
Stakeholder communication	A	I	–	I	C	C	R	C	I
Assessment of reporting obligations	C	–	C	–	I	R	I	A	I
Eradication and credential reset	A	R	C	R	I	–	I	I	I
Restoration approval	R	C	C	R	A	I	I	C	I
Exam continuity decision	R	I	–	C	A	C	C	C	I
Closure and post-incident review	R	C	C	C	C	C	C	A	R

Key: IRL Incident Response Lead; SA Security Analyst; FOR Forensics Lead; ITO IT Operations Lead; BO Business Owner; LEG Legal and Privacy Adviser; COM Communications Lead; EXEC Executive Sponsor; SCR Scribe and Evidence Custodian. Red cells show the single Accountable role. Green cells show Responsible roles.

Design choices. The IRL is accountable for operational activities, as on slide 15, but not for regulatory decisions (EXEC, because the institute is the controller) or service return (BO, because the business bears the risk). Restoration approval has IRL and ITO responsible for recommending and executing, and the BO accountable for deciding. This stops the technical team from approving its own work.

2.4 Readiness checklist and preparation improvements

Table 9. Preparation improvements. The resources column lists what is needed, without invented prices. Owners are roles.

#	Improvement	Owner	Resources needed	How readiness is checked
1	**Backup readiness.** Keep at least one offline or immutable copy of FS01, LMS01 and M365 data. Remove standing admin reach from svc_backup. Define RTO and RPO per system from the BIA.	ITO (accountable: EXEC)	Immutable or offline storage, backup software settings, time to design and approve RTO and RPO.	Documented restoration test of a full system every quarter, timed against RTO. Evidence report filed. No test older than 90 days.
2	**Accessible incident contact list.** Hold a printed and an offline copy, not only on FS01. Include staff mobiles, providers, counsel, DFIR and regulators.	Scribe	Printed cards, sealed envelopes with IRL, ITO and Director, a personal-device encrypted copy.	Monthly call test of ten random numbers, with the result logged. Contact list kept off the production file server.
3	**Detection tools.** Extend EDR to all servers, centralise logs (including proxy, M365 and Windows security) with alerts for off-schedule privileged logons and large uploads.	SA	EDR licences for servers, log collection or lightweight SIEM, alert rules.	Coverage report shows 100% of servers and workstations. Test alert fires within 10 minutes in a controlled test.
4	**Secure communication.** Pre-agree an out-of-band channel (phone tree, SMS service, and an alternative mailbox outside the primary tenant) and a public status page that does not depend on LMS01.	COM	Alternative email domain or mailbox, SMS gateway or broadcast list, template library.	Quarterly drill: IRL sends a test notice to the CSIRT and a sample of learners within 15 minutes using only the alternative channel.
5	**Privileged access.** Vault and rotate service credentials, enforce MFA and conditional access for admins and finance staff, and remove admin rights where not needed.	ITO	Password vault, conditional access policies, access review time.	Quarterly access review. Report of all accounts with admin rights. Sign-in policy test.
6	**Training and exercise.** Role-specific CSIRT training, phishing awareness for all staff, and a tabletop at least once a year (ICDFA, n.d., slide 8).	IRL	Half-day workshops, phishing simulation tool, exercise scenario.	Attendance 100% of CSIRT. Phishing report rate trend. Tabletop actions closed on time.
7	**Forensics and legal readiness.** Contract an external DFIR provider and legal counsel with incident terms, and prepare evidence-handling kit (write blockers, encrypted storage, forms).	EXEC	Signed retainer or call-out agreement, evidence jump kit.	Provider response time confirmed in a call test. Kit inventory checked every six months.

Task 3 – Response playbook and evidence preservation (25 marks)

Stage: Containment, Eradication and Recovery, with evidence handling from Detection and Analysis (ICDFA, n.d., slides 10–11). Method: contain first to stop harm, but preserve what I can before each change. The CISA guide supports isolating affected systems while preserving volatile evidence, treating power-off as a last resort, using out-of-band communication, and checking backups for malware before restoration (CISA et al., 2023). All times are WAT on Day 0 (Monday) unless stated. Every action below is a **plan**; none has been performed.

3.1 Response playbook

Table 10. Ordered playbook for the first 60 minutes (steps 1–9) and the remainder of the first 24 hours (steps 10–19). Evidence IDs refer to Table 11.

Step / time / stage	Action	Owner	Required approval	Evidence to retain	Completion check
1 08:45–08:50 Declare	Declare a **Critical** incident. Open the incident log and decision log. Start a written clock. Assign roles. Treat corporate email as untrusted (E08).	IRL (Scribe logs)	Pre-delegated authority (A2). Executive Sponsor informed by phone.	Incident log entry; time of declaration; role assignment.	Log opened with time stamp. Roles confirmed by phone.
2 08:50–09:00 Communicate	Phone the core CSIRT and the Executive Sponsor. Open an out-of-band conference bridge by voice call. Use staff mobiles (E08, A8). Tell helpdesk to reroute learner queries to a holding script.	IRL; COM	None (Critical trigger).	Call log with times and attendees.	All core roles reached or an alternate named.

Step / time / stage	Action	Owner	Required approval	Evidence to retain	Completion check
3 08:55–09:05 Short-term containment	Isolate **FS01**: block its network port or VLAN, or disable its NIC. Do **not** power off. Screenshot the ransom note and sample .locked files first. Isolate **FIN-PC07** using EDR network containment, keeping it powered.	ITO (SA for EDR)	IRL (delegated).	Photographs of the ransom note. EDR isolation record. Switch or hypervisor change record with time. Planned EV-01, EV-03.	Pings from the user network to FS01 and FIN-PC07 fail. EDR shows host isolated.
4 09:00–09:10 Protect backups	Disable **svc_backup** everywhere. Disconnect **BAK01** from the network, or block its SMB and management ports. Suspend backup jobs and retention or expiry deletion. Locate and physically secure the **Friday 17:00** disconnected backup.	ITO	IRL.	Account audit log. BAK01 configuration export. Photograph of the secured media. Planned EV-05, EV-07.	svc_backup shows disabled. No inbound connection to BAK01 from any host. Media location confirmed.
5 09:05–09:20 Identity containment	Export M365 sign-in and audit logs **first**, then revoke all sessions and tokens for the finance officer, reset password, require MFA re-registration, and block the unfamiliar IP and device. Review inbox rules, forwarding, OAuth app consents and MFA methods. Reset passwords for privileged M365 and local admin accounts.	ITO; SA	IRL.	Exported logs (EV-04). Screenshots of rules and consents found.	Revocation confirmed in the audit log. No unknown rules, consents or MFA methods remain.
6 09:10–09:20 Suspicious transfer	Block the destination of the 1.2 GB upload at the proxy and firewall. Preserve proxy logs. Ask counsel to prepare a preservation or takedown request to the cloud provider.	SA; LEG	IRL; LEG for the provider request.	Proxy log export (EV-06). Destination domain and IP.	Block rule active. Further attempts to reach the destination are seen in logs.
7 09:15–09:30 Volatile evidence	Where safely achievable within about 15 minutes, take memory and a triage collection from FIN-PC07 and FS01, using the EDR or a trusted tool. Do not install new tools on FS01 beyond the minimal capture agent. If external DFIR is not on site, SA collects what can be collected and records what is lost.	SA (FOR guides remotely)	IRL; FOR if available.	Planned EV-02, EV-03. Evidence-loss note for anything not captured.	Collection recorded in the register with planned hash step. Loss note written if skipped.
8 09:30 Brief and escalate	Brief the Executive Sponsor in writing (Task 4). Engage external DFIR and legal counsel. Start the 72-hour regulatory clock record (Task 4) as a precaution.	IRL; EXEC	EXEC approves external engagement and spending.	Executive briefing as sent. Time of DFIR and counsel call.	DFIR and counsel confirm availability and arrival time.
9 09:45 Exam and portal	Take a read-only snapshot of LMS01. Assess whether LMS01 itself is clean (Q4). Prepare the examination go/no-go criteria for 10:00 (Decision 2).	ITO; SA	BO decides at 10:00.	LMS01 snapshot reference. Integrity check results.	Go/no-go criteria sheet complete. Decision recorded.
10 10:00–10:15 Decision gate	Examination go/no-go. Default: **postpone** unless every criterion in Decision 2 is met. Send learner notice by 10:15 (Task 4).	BO (A); IRL (R)	BO with EXEC informed.	Decision record and rationale. Notice as sent.	Learners informed by 10:15. Decision log updated.
11 10:15–12:00 Scope sweep	Sweep for indicators of compromise from FIN-PC07 on every workstation using EDR. Triage all servers manually, since EDR coverage is incomplete. Check for new local admins, scheduled tasks, remote-access tools and unknown services. Review proxy logs for other transfers. Search for the ransom note and .locked files on every share.	SA; ITO	IRL.	Sweep query and results. List of hosts checked and unchecked.	Every host marked clean, suspect or not checked. Uncovered hosts have a named owner.
12 10:15–13:00 Investigate	Analyse the entry vector (Q1): message trace, attachment sample in an isolated sandbox, EDR process tree. Analyse svc_backup (Q2) and the upload (Q3). Identify the ransomware family from the note and a sample, with no ransom-contact or payment step without counsel and the Executive Sponsor.	FOR; SA	IRL.	Sandbox report. Logon analysis. Timeline updates. Planned EV-08.	Q1–Q3 each have a written finding or a stated blocker.
13 12:00–15:00 Backup validation	Select and validate a backup (3.4). Restore a copy into an **isolated** environment. Scan, compare integrity and test application function.	ITO; FOR	IRL; BO informed.	Restore log. Scan results. Integrity report.	Backup meets acceptance criterion 1 (3.5), or is rejected in writing.

Step / time / stage	Action	Owner	Required approval	Evidence to retain	Completion check
14 13:00–17:00 Longer-term containment	Rotate all privileged and service credentials. Apply conditional access and MFA for admins. Segment LMS01, BAK01 and FS01 so that one admin path cannot reach all. Block newly seen indicators. Extend EDR to servers where feasible.	ITO; SA	IRL.	Change records. Rotated account list.	No old credential still works. Segmentation tested.
15 15:00–Day 1 06:00 Eradication	Rebuild FIN-PC07 and FS01 from known-good images, not cleaned in place. Remove persistence found in step 11. Patch the exploited weakness. Confirm that the mail filter now blocks the attachment type or sender.	ITO; FOR confirms	IRL; BO informed.	Rebuild records. List of persistence removed.	Rebuilt hosts pass malware scans. No indicators remain after rescan.
16 17:00–21:00 Briefings	Update executives (every 2 hours), staff, and learners. Review the attacker's claim and threat deadline with counsel. No public statement on data unless approved by LEG and EXEC.	COM; IRL	EXEC and LEG.	Notices as sent. Log of attacker contact (if any).	Updates sent on schedule.
17 Day 1 06:00–14:00 Recovery	Restore in the agreed order (3.4) into a segmented network. Check integrity of restored data (hash lists, sample opens, application tests). Run enhanced monitoring.	ITO; SA	BO (A) for each service return.	Restore logs. Integrity test records.	Each service meets its acceptance criteria before release.
18 Day 1–Day 7 Monitoring	Enhanced monitoring for 7 days. Re-check for persistence, new sign-ins, mail rules and uploads. Daily stand-up.	SA	IRL.	Daily monitoring report.	No unexplained indicator for 7 consecutive days.
19 Day 1 Closure of operations	Hand off from incident mode to normal operations when acceptance criteria are met. Close the evidence register with custody records. Schedule review.	IRL; EXEC	EXEC (A).	Closure memo. Final register.	All register items have custody to date. Review meeting scheduled.

That is 19 ordered actions: nine in the first hour of the clock (08:45–09:45), and ten for the rest of the first 24 hours (steps 10–19; steps 18–19 extend to the first week).

How I will check for broader compromise

- **Hosts:** EDR indicator sweep across all workstations, and manual triage of all servers where EDR is missing, using hashes, filenames, persistence locations and network indicators from the first hosts.
- **Accounts and cloud:** review M365 sign-ins from the unfamiliar IP or device for every user (not only the finance officer), inbox rules, forwarding, OAuth consents, newly registered MFA methods and mailbox permissions.
- **Privileged paths:** every system where svc_backup or any admin account logged on in the last 30 days; any new accounts or group changes.
- **Network and data:** proxy, DNS and firewall logs for large outbound transfers or beaconing in the 14 days before E01 and since, including repeat contact to the E04 destination.
- **Third parties:** confirm with the backup, cloud and email providers that they see no unusual activity in their own logs.

Limits: with incomplete server EDR coverage and no known log retention period (**unresolved**), a clean sweep reduces risk but does not prove absence of compromise. That limit is stated in every briefing.

3.2 Two difficult decisions

Decision 1 – Containing while preserving useful evidence

Decision: Isolate FS01 and FIN-PC07 from the network immediately and leave both powered on. Capture volatile data only if it can be done within about 15 minutes without delaying isolation of FS01.

Rationale. Mass file changes were seen at 08:30 (E06), so encryption may still be spreading to other shares, and BAK01 is reachable by an account the attacker may control (E03). Each extra minute risks more data lost, and loss of the backups would remove my main recovery option. Memory and running-process data is useful for finding the encryption key material, the attacker's tools and persistence, but it is lost on shutdown, so I avoid powering off (CISA et al., 2023). Network isolation stops spread and keeps memory. The slide deck makes the same sequence explicit: isolate, then preserve before further change (ICDFA, n.d., slide 11).

When immediate isolation, with no evidence capture first, is necessary. (a) Encryption is visibly spreading to new hosts or shares. (b) BAK01 or backup media show signs of active access, deletion or encryption. (c) Data is currently leaving the network. (d) The attacker is interactively active. Any one of these overrides evidence capture. At 08:45 (a) and (b) are possible and so I isolate first and capture second.

How evidence loss and impact are documented. The Scribe records for each action the time, the person, the reason, what was and was not captured, and the business impact (for example, finance staff cannot work and FS01 shares are offline). Anything not captured is entered in an **evidence-loss note** and given to the forensic provider and counsel, so that an investigator or regulator can see that the loss was a deliberate, reasoned trade-off. This is an operational impact that the Executive Sponsor is told about in the 09:30 briefing.

Decision 2 – Restoring examination access while backup safety is uncertain

Options considered.

Option	Benefit	Risk	Verdict
A. Reopen the portal on current FS01 and LMS01 and run the 11:00 examination.	Meets the deadline.	Serves content from an encrypted or compromised server. Risks reinfection, corrupt results, learner data exposure, and loss of evidence.	Rejected.
B. Restore LMS01 content from the Friday 17:00 disconnected backup into a clean, isolated environment and run the examination.	Uses the most trustworthy backup (A7), and keeps the exam.	Needs identity reset, validation and testing in about 75 minutes, and submissions have no safe place to land if FS01 is down. Backup not yet tested (Q2).	Only if all five gate criteria are met by 10:00.
C. Postpone the examination and give learners a new date.	Safe. Fully reversible. Time for validation.	Disruption to 100 learners. Reputational cost. Possible institutional or accreditation rules on assessment dates (**unresolved**).	Default.

Decision: Hold a go/no-go gate at **10:00**. Postpone (Option C) unless **all** of these are true: (1) LMS01 is shown clean by snapshot scan and integrity comparison; (2) content is restored from a validated backup into an isolated segment, not on the compromised FS01; (3) the M365 accounts of the 100 learners and examiners are not in scope of the compromise and the finance session revocation is complete; (4) a safe place exists for submissions, with a plan for recovering them; (5) the Business Owner accepts the residual risk in writing. If any criterion fails, we postpone and tell learners by 10:15.

Rationale. Delay is recoverable, but corrupted assessment records, reinfected systems and exposed learner data are not. A false restoration also risks the integrity of the very recovery path that all other services depend on. This is a business risk decision, and so the Business Owner (A) makes it with advice from me (R), as in the RACI (Table 8). The decision log records the data loss (work since Friday 17:00) and the operational impact of postponement.

3.3 Evidence register and custody arrangements

Status of every item is "planned / not yet collected". I have not performed any acquisition, and the register contains no hash values. Integrity values are to be computed at the time of collection and recorded then. Dates and times are targets in WAT (UTC+1).

Table 11. Evidence register (planned). CoC = chain of custody form.

ID	Source	Proposed collection method	Collector role	Date and time (WAT)	Integrity check	Secure storage	Custody transfers
EV-01	FIN-PC07 disk and EDR telemetry (E01, E04, E06)	EDR triage package and, if DFIR agrees, forensic disk image taken via write-blocked or approved tool after isolation.	SA, then FOR	Not yet collected. Target Day 0 10:00–14:00.	SHA-256 of image and package, to be computed at acquisition and recorded on the CoC.	Encrypted external drive in evidence safe. Working copy on separate analysis system.	To be recorded on CoC-01: SA → Scribe → FOR.
EV-02	FIN-PC07 memory	Memory capture with approved tool before any reboot.	SA	Not yet collected. Target Day 0 09:15–09:30.	SHA-256 at capture. Tool and version recorded.	As EV-01.	CoC-02: SA → Scribe → FOR.

ID	Source	Proposed collection method	Collector role	Date and time (WAT)	Integrity check	Secure storage	Custody transfers
EV-03	FS01: memory, triage collection, ransom note, sample .locked files, event logs	Minimal-footprint triage collector. Photograph the note and file names. Export event logs. Full image later by FOR.	SA, then FOR	Not yet collected. Target Day 0 09:15–09:45 (triage), image by 14:00.	SHA-256 of each file or container at collection.	As EV-01. Separate container per host.	CoC-03: SA → Scribe → FOR.
EV-04	M365 audit, sign-in and mailbox logs for finance officer and all users (E02)	Export via admin portal or API before any revocation, under a named administrator account with MFA.	ITO under SA supervision	Not yet collected. Target Day 0 09:00–09:15.	SHA-256 of exported files. Export query and time recorded.	Encrypted evidence store, offline copy.	CoC-04: ITO → Scribe → FOR.
EV-05	Windows Security logs from FS01 and BAK01, svc_backup activity (E03)	Export .evtx files and event query results.	ITO	Not yet collected. Target Day 0 09:10–09:30.	SHA-256 at export.	As EV-04.	CoC-05: ITO → Scribe → FOR.
EV-06	Proxy and firewall logs, 1.2 GB upload (E04)	Export the full log slice for the 14 days before E01 to the present.	SA	Not yet collected. Target Day 0 09:15–09:40.	SHA-256 of exports.	As EV-04.	CoC-06: SA → Scribe → FOR.
EV-07	BAK01 configuration, job catalogue, retention settings, and Friday 17:00 disconnected media (E05)	Export configuration after network isolation. Photograph and seal the Friday media. Do not mount it on a production host.	ITO; Scribe seals	Not yet collected. Target Day 0 09:10–09:30.	SHA-256 of exports. Media serial number and seal number recorded.	Sealed media in safe, signed in and out.	CoC-07: ITO → Scribe → FOR.
EV-08	Original phishing email and attachment (E01)	Export the message as .eml with headers from the mail platform. Handle the attachment only in a sandbox.	SA	Not yet collected. Target Day 0 10:15–11:00.	SHA-256 of .eml and attachment.	Encrypted evidence store, offline.	CoC-08: SA → Scribe → FOR.

Access restrictions and custody rules. (1) Only the Scribe/Custodian, the IRL and the forensic provider can open the evidence store. (2) Evidence is held on encrypted media kept off the compromised domain, with an offline copy. (3) Originals are never examined directly, and only working copies are analysed. (4) Every transfer is recorded on the chain-of-custody form with date, time (WAT), from, to, purpose and hash re-check. (5) Anyone taking evidence signs it out and back in. (6) Hash values are written down at collection by the collector and verified by a second person at transfer (ICDFA, n.d., slides 7 and 10). (7) Counsel is told what is collected, so privilege and disclosure can be managed.

3.4 Eradication, credentials and recovery

Persistence removal, entry point and credentials

- **Persistence.** Treat every host in scope as untrusted. Rebuild FIN-PC07 and FS01 from known-good images instead of cleaning them. For other hosts with indicators, remove scheduled tasks, services, registry run keys, startup items, unknown remote-access tools and new local accounts, then re-scan with more than one tool and re-check after 24 hours (ICDFA, n.d., slide 11).
- **Entry point.** The likely vector is the payroll attachment (E01, **hypothesis**). I will confirm it by message trace and sandbox analysis, remove the message from all mailboxes, block the sender and file type, and check for any other recipients. I will keep an open mind about alternatives (an exposed remote service or a stolen credential) until the evidence rules them out.
- **Credentials.** Reset the finance officer's password and sessions and re-register MFA. Rotate svc_backup, all administrator, break-glass and service credentials, and API keys, and issue them from a clean device. Revoke OAuth consents and unknown MFA methods. Require MFA for all admins. Do not reuse svc_backup. Create a replacement with least privilege and no standing admin reach across FS01 and BAK01.

Recovery order and targets

Table 12. Recommended restoration order and targets. RTO and RPO are my proposals for approval by the Business Owner, because the brief gives none.

Order	Service	Why this order	Target: restored by	Acceptable data loss (RPO)
1	Identity and email hygiene (M365 clean-up, alternative channel)	Everything else depends on trusted identity and communications.	Day 0 by 12:00	None (cloud service; settings only).

Order	Service	Why this order	Target: restored by	Acceptable data loss (RPO)
2	FS01 content needed by the portal, restored into an isolated segment	The portal depends on FS01 files (A6).	Day 1 by 10:00	Up to Friday 17:00 (about 63 hours 45 minutes). Work since then is re-created or re-submitted (A9).
3	LMS01 learning portal and examination service	Business-critical. Needed for the examination re-run.	Day 1 by 14:00, subject to Decision 2 criteria	As FS01.
4	FS01 general shares	Needed by staff, but lower than teaching.	Day 2	As FS01.
5	FIN-PC07 and finance files	Rebuild first, then restore data after checks. Finance is sensitive and subject to scrutiny.	Day 2–3	As FS01, with reconciliation by finance.
6	BAK01 rebuild with immutable or offline copy	No new backups are safe until the repository is rebuilt.	Day 2–3	n/a

The Friday 17:00 to Monday 08:45 gap is 63 hours 45 minutes. Any later network backup is used only if validated as clean (A7, A9).

Selecting and validating a backup

1. **Candidate selection.** List all restore points: the Friday 17:00 disconnected backup and the network backups (including the 02:00 jobs in E05). Choose the **most recent point before the earliest evidence of compromise** (E01, Sunday 16:40, plus margin for unknown dwell). The Friday disconnected copy is the default. Any later network copy is a candidate only if it passes all checks.
2. **Provenance.** Confirm the media or snapshot was not mounted on a compromised host since Friday (EV-07), and compare job logs, catalogue and timestamps with BAK01 activity from E03.
3. **Isolated test restore.** Restore into an isolated network with no route to production, using new credentials.
4. **Malware and integrity checks.** Scan with more than one tool, search for ransom-note files, .locked extensions, known indicators and unexpected binaries. Compare file counts, sizes and hashes of a sample with known-good data (for example, vendor packages for LMS01). Check that files open and databases mount.
5. **Controlled production restore.** Restore to rebuilt systems on a segmented network with only the access needed. Keep the isolated copy for evidence.
6. **Monitoring before approval.** Run the restored service under enhanced monitoring, then present results to the Business Owner.

3.5 Recovery acceptance criteria

The Business Owner may approve return of a service only when **all** of the following are met and recorded:

1. The backup used was validated (provenance, isolated restore, scans and integrity tests all passed and documented).
2. The host or service runs on a rebuilt or verified-clean platform, and sweep results show no indicators of compromise on it.
3. All credentials that could reach the service were rotated, and no old credential works. MFA is enforced for admin and finance access.
4. The entry point is identified and fixed or mitigated, or an explicit compensating control is accepted by the Executive Sponsor.
5. Application tests pass (login, content access, submission and results retrieval, for the portal) with sample data checked against known values.
6. Enhanced monitoring is live, with alerting for the indicators found, and no unexplained alert for at least 24 hours before return and 7 days after.
7. Data loss against RPO is documented and accepted in writing, and affected users know what must be re-created.
8. Evidence has been captured and custody records are up to date, so rebuilds do not destroy needed evidence.
9. Rollback is defined: if a new indicator appears, the service is isolated again.

Task 4 – Communication and escalation (10 marks)

Stage: Preparation (communication plans) and Containment, Eradication and Recovery (executing them). Communications follow the slide guidance on internal notification, external protocols and pre-approved statements (ICDFA, n.d., slide 8), and the rule that email may be untrusted (E08). All numbers and web addresses below are **fictional**.

4.1 Communication matrix

Table 13. Communication matrix. Primary channel is used while it is trusted. The alternative channel is used if corporate email is unsafe or unavailable.

Stakeholder	Trigger	Message owner	Primary / alternative channel	Approver	Update frequency
Learners (all 1,800; the 100 sitting the exam first)	Declaration of Critical incident, and any change to examination status.	COM	Primary: SMS broadcast and public status page. Alternative: phone call to examination cohort, notice at the campus entrance, and social media page managed by COM.	EXEC (BO for exam content)	First notice by 10:15, then every 4 hours or on any change.
Executive management	Declaration. Any decision requiring approval. Any change in severity.	IRL	Primary: phone call and a short written note by SMS. Alternative: in-person briefing.	IRL	Every 2 hours during Critical, or on trigger.
IT and security staff	Declaration. New containment instructions.	IRL	Primary: phone bridge. Alternative: group messaging on personal phones (no sensitive details).	IRL	Hourly during first 12 hours.
All staff	Declaration, plus when systems are isolated or loss of service is expected.	COM	Primary: SMS or phone tree. Alternative: all-hands in person, notice board, alternative mailbox.	EXEC	Twice a day, or on change. Instruction: do not use FS01, do not open unexpected attachments.
Service providers: external DFIR, Microsoft 365 support, backup and ISP	Containment is not confirmed within 60 minutes, or need for specialist support or provider-side logs.	ITO (DFIR: IRL)	Primary: provider emergency phone line. Alternative: named account manager on mobile.	EXEC (spend), IRL (scope)	On engagement, then at least every 4 hours.
Legal and privacy advisers	Suspected personal data exposure (Q3), attacker claim, regulator or media contact.	IRL	Primary: phone call. Alternative: encrypted messaging from a personal device, no email until the tenant is cleared.	IRL	On trigger, at least every 4 hours.
Regulator (Nigeria Data Protection Commission, if counsel advises)	Counsel assesses a notifiable breach (4.3).	LEG	Primary: the regulator's official breach notification route. Alternative: as counsel advises.	EXEC, on LEG advice	Initial notice, then phased updates.
Law enforcement and national CERT	Counsel and EXEC decide to report, especially for extortion.	LEG	Primary: official reporting channel. Alternative: in-person.	EXEC	On decision, then as requested.
Media and public	Journalist enquiry or public post about the incident.	COM	Primary: holding statement by phone or website. Alternative: spokesperson only.	EXEC with LEG	Single statement, then updates only with approval.

Escalation rules

1. **E-1 Declare Critical** for ransomware, suspected exfiltration of personal data, or doubt about backup integrity. Executive Sponsor informed within 15 minutes.
2. **E-2 Legal and privacy** are consulted within 30 minutes of any suspicion that personal data may be involved.
3. **E-3 External DFIR** is engaged if containment is not confirmed within 60 minutes, or if the team cannot scope the incident, or if Critical lasts 4 hours.
4. **E-4 Examination decision gate** at 10:00 and any later gate the Business Owner sets. If criteria are not met, the examination is postponed.
5. **E-5 Media, regulator, law-enforcement and attacker contact** is handled only by COM, LEG and EXEC. Staff pass all enquiries to COM. No one replies to the attacker without LEG and EXEC approval.
6. **E-6 If email is suspected**, no sensitive detail is sent by email. Switch to the alternative channel on the matrix.

7. **E-7 Severity change** (up or down) is announced to the matrix groups listed for that level, and logged with the reason.

4.2 Executive briefing and learner notice

Executive briefing draft (158 words; required 150–200). Prepared for 09:30 in the plan, on the assumption that the steps in playbook rows 3–7 are under way.

Executive briefing – 09:30 WAT, Monday (Day 0). Classification: Critical (provisional).

Confirmed: Ransomware-type encryption has affected the finance workstation FIN-PC07 and the shared file server FS01, and a ransom note is present (E06). The learning portal loads, but learners cannot open materials or submit work (E07). Our incident contact list was on FS01 and is unavailable (E08). The 11:00 examination for 100 learners is at risk.

Uncertain: We do not yet know how the attacker entered, whether learner or finance data left our network (a 1.2 GB upload occurred, E04), whether the backup system was tampered with (E03), or whether email can be trusted.

Actions under way: Affected systems are isolated, the backup account is disabled, and evidence is being preserved.

Decisions needed by 10:00: (1) approve postponing the 11:00 examination unless the portal is verified safe; (2) approve engaging an external forensic provider; (3) authorise legal counsel to assess notification duties.

Next update: 10:30 WAT, by phone.

Learner notice draft (123 words; required 100–150). Written for the "postpone" outcome at the 10:00 gate. If the gate is passed, only the examination paragraph changes.

Notice to learners – Monday, 10:15 WAT

Northbridge Skills Institute is dealing with a technical security incident affecting some of our systems.

Your examination: the 11:00 online examination will **not** take place at that time. Your place is protected and a new date will be confirmed by 14:00 today.

What to do: Please do not log in to the learning portal today. Ignore any message, text or social media post about the examination, results or payments unless it comes from the sources below. Never click links or share passwords.

Official updates: www.northbridge.example/status or the helpdesk on +234 000 000 0000 (fictional), 08:00–18:00.

We have no confirmed evidence yet that your personal information has been accessed. We will tell you promptly if that changes.

4.3 Notification obligations: how legal and privacy advisers will decide

Operational notices versus formal breach notification. The notices above (learners, staff, executives and providers) are **operational**. They tell people what to do and what service to expect, and they say what is and is not known. A **formal breach notification** is a legal act to a regulator and, if required, to data subjects. It has its own content, deadline and approval, and it is decided by counsel and the Executive Sponsor (RACI: LEG responsible, EXEC accountable). The operational learner notice does not state that data has been stolen, because that is unconfirmed (Q3), and it does not state that data is safe, because that is also unconfirmed.

Process.

1. **Facts.** I give counsel a short fact sheet every 4 hours: what data sets sit on FS01, FIN-PC07 and M365, what is confirmed, what is not, and the status of Q3 (what was in the upload).
2. **Applicability and jurisdiction.** Counsel confirms who the data controller and processors are, the law that applies and any contractual duties, including those to learners in other countries and to sponsors or accreditors (**unresolved**; assumption A1 is Nigeria).
3. **Risk assessment.** Counsel decides whether the breach is likely to risk the rights and freedoms of learners, and whether the risk is high, using the data types, volume, the extortion claim and whether data was encrypted or already exposed.
4. **Recipients and deadlines.** Counsel confirms recipients (regulator, data subjects, any partners) and the deadline, and the Scribe records the "time of awareness" and the reasoning.
5. **Content and approval.** LEG drafts, EXEC approves, COM issues. The notification can be phased as facts emerge.

Jurisdiction and source (assumption A1). If Northbridge is a Nigerian data controller, then, as summarised by a secondary legal commentary on the Nigeria Data Protection Act 2023 (NDPA), section 40(2) requires the controller to

notify the Nigeria Data Protection Commission **within 72 hours** of becoming aware of a breach that is likely to risk the rights and freedoms of data subjects, with information provided in phases if needed, and section 40(3) requires data subjects to be told **immediately** where the risk is high (Federal Republic of Nigeria, 2023; Afriwise, n.d.). As a precaution, I start a record of the 72-hour clock at the 09:30 briefing, from 08:45 on Day 0, so the working outer limit would be 08:45 on Thursday (Day 3); counsel determines the true time of awareness. These section references come from a secondary summary, so counsel must check them against the official Act text and any Commission guidance before they are relied on. I do not assert a deadline for any other jurisdiction.

Task 5 – Tabletop exercise and improvement plan (15 marks)

SIMULATION NOTICE. Everything in this task is a **simulated, fictional exercise** that I ran alone on paper, playing each role in turn. No real system, person or regulator was involved. The "results" are my reasoned simulation and are not observations from a real incident. The exercise tests the plan from Tasks 1–4 (ICDFA, n.d., slides 8 and 18).

5.1 Exercise design

Objectives

1. Test whether the declaration, authority-to-isolate and containment sequence in the playbook works within the target times.
2. Test the examination go/no-go gate under management pressure to reopen the portal.
3. Test backup selection and validation, including what happens when a backup fails.
4. Test communication discipline under pressure: attacker claim, social media and a journalist.
5. Test the decision log and the evidence register as working tools.

Participant roles

Each role below is played by me in turn, speaking from that role's responsibilities in Table 7 and Table 8: Incident Response Lead (IRL, facilitator), Security Analyst (SA), Forensics Lead (FOR), IT Operations Lead (ITO), Business Owner (BO), Legal and Privacy Adviser (LEG), Communications Lead (COM), Executive Sponsor (EXEC) and Scribe (SCR). In a live version, each role is played by its holder and I would act only as facilitator (assumption A10: minute 0 = 08:45 WAT on Day 0).

Agenda (60 minutes)

Minute (clock)	Activity
0–10 (08:45–08:55)	Scenario brief. Roles confirmed. Declaration, first containment and communication steps (playbook steps 1–5).
10 (08:55)	**Inject 1** – Management asks to reopen the portal before 11:00, even with an unverified backup. Discussion and decision.
20 (09:05)	**Inject 2** – Attacker claims to hold all 1,800 learner records, threatens publication in 12 hours (deadline 21:05), and supplies a screenshot of unknown authenticity.
28 (09:13)	**Inject 3 (my own)** – Alert: a new inbox rule and an OAuth consent appear on the finance account, and a sign-in to a senior manager's mailbox from the same unfamiliar IP.
35 (09:20)	**Inject 4** – Test restoration of the latest network backup fails with an unreadable snapshot error.
45 (09:30)	**Inject 5** – A social media post claims the examination is cancelled. A journalist asks whether learner information has been exposed.
50–60 (09:35–09:45)	Hot wash: evaluate against success criteria, list improvements, assign owners.

Measurable success criteria

ID	Criterion	Target
SC1	FS01 and FIN-PC07 isolated and svc_backup disabled, with each action logged.	Within 20 minutes of declaration (by minute 20)
SC2	Every inject receives a logged decision with owner and rationale.	Within 5 minutes of the inject; 100% of injects

ID	Criterion	Target
SC3	No service is restored or reopened from an unvalidated backup.	Zero exceptions
SC4	First written executive briefing issued; any external statement approved by LEG and EXEC before release.	Briefing by minute 30; 100% of external statements approved
SC5	Evidence-register entry (or evidence-loss note) opened for every containment action.	100% within 10 minutes of the action
SC6	No sensitive incident detail sent over corporate email.	Zero exceptions

5.2 Simulated walk-through (role by role)

Table 14. SIMULATION: walk-through of each inject, with the view of each participant.

Minute	Inject	Role-by-role walk-through (simulation)
0–10	Declaration	**IRL:** declare Critical, open logs, start the phone tree. **SA:** EDR-isolate FIN-PC07, start sweep. **ITO:** ask for FS01 port block. **SCR:** open the incident log. **EXEC:** told by phone, asks about the exam. **COM:** ready a holding script for helpdesk.
10	1. Management wants the portal reopened before 11:00	**EXEC:** "Learners are waiting. Can we reopen on the last backup?" **IRL:** the last backup is unverified (E05) and the account that can reach it was used off-schedule (E03), so I advise against reopening on current storage. **BO:** I own the exam, so I need the options and the risk. **ITO:** an isolated restore from the Friday disconnected copy is possible but unproven and tight. **FOR:** a restored but infected portal destroys evidence and risks reinfection. **COM:** a late cancellation hurts more than an early one. **Outcome:** keep the 10:00 gate with five criteria. Postponement is the default.
20	2. Attacker claims 1,800 records, 12-hour deadline	**SA:** the screenshot could be from E04's data, from another breach, or fabricated. **FOR:** compare the screenshot's file names and fields against FS01 and the 1.2 GB upload, once EV-06 is exported. **LEG:** do not reply or negotiate, preserve the message, and pre-assess notification (clock started at 08:45). **IRL:** treat the claim as credible but unverified, keep scope at "possible exposure". **EXEC:** do not pay or reply without legal advice. **COM:** no public statement on data yet. **SCR:** log the time the claim was received and the deadline of 21:05.
28	3. (My own) New mail rule, OAuth consent, and senior manager mailbox sign-in	**SA:** the attacker still has a foothold in M365, which is wider than the file server (Q1, Q5). **ITO:** revoke all sessions, remove the rule and consent, force password reset and MFA re-registration for the senior manager and finance officer. **IRL:** treat email as untrusted for all management, move updates to phone, widen the sweep to all executives. **LEG:** mailbox access is a potential personal data and privileged communication issue. **SCR:** log EV-04 export done before revocation.
35	4. Network backup test fails (unreadable snapshot)	**ITO:** the latest network backup cannot be restored. **FOR:** possible corruption, encryption or tampering by the attacker, so preserve the snapshot as evidence. **IRL:** switch to the Friday 17:00 disconnected backup as the source (A7), and accept data loss of about 63 hours 45 minutes (A9). **BO:** I accept the loss of work since Friday for planning, but cannot confirm the exam can run. **EXEC:** informed of the revised recovery estimate. **COM:** prepare a revised learner message.
45	5. Social post says exam cancelled. Journalist asks about exposure	**COM:** confirm the real exam position (not cancelled; under review with a decision due at the 10:00 gate and a notice by 10:15), publish that correction on the status page, and give the journalist the approved holding statement. **LEG:** wording must not say data is safe or that it was stolen. **EXEC:** approves the statement. **IRL:** log the request, no technical details. **SCR:** log the journalist's name, time and statement given.

5.3 Decision log (simulation)

Table 15. SIMULATION: decision log with seven entries.

#	Inject	Decision	Decision owner	Rationale	Communication	Effect on the response or recovery plan
D1	Start (min 0–10)	Declare Critical. Isolate FS01 and FIN-PC07 without powering off. Disable svc_backup. Cut BAK01 off the network.	IRL	Active encryption (E06), privileged account misuse (E03), and backup risk (E05). Authority is pre-delegated (A2).	Phone to CSIRT and EXEC. Log entry.	Starts SC1 clock and evidence register. Evidence-loss risk accepted and logged.
D2	1 (min 10)	Do not reopen the portal on current storage. Hold a 10:00 gate with five criteria. Default postpone.	BO (advised by IRL)	Risk of reinfection and corrupt results outweighs a delay. Delay is reversible, data corruption is not.	EXEC told verbally. Draft learner notice prepared.	Exam moves to a conditional plan. Isolated restore preparation begins in parallel.

#	Inject	Decision	Decision owner	Rationale	Communication	Effect on the response or recovery plan
D3	2 (min 20)	Treat the claim as credible but unverified. No reply or negotiation. Preserve the message and start phased notification preparation.	EXEC (advised by LEG)	No evidence yet of what was taken (Q3). Replying risks escalation and legal exposure.	Counsel updated. No public statement.	Q3 raised to top priority. Notification package drafted early in case it is needed by the 72-hour mark.
D4	3 (min 28)	Revoke all M365 sessions and reset credentials for finance and senior managers. Treat corporate email as untrusted for management updates.	IRL	Foothold in the identity layer could undo the containment of the file server.	Phone calls to managers. No email.	Adds identity eradication tasks and widens the sweep (Q5). Slows return to normal email.
D5	4 (min 35)	Abandon the network backup as primary source. Use the Friday 17:00 disconnected copy after validation. Preserve the failed snapshot as evidence.	IRL (BO accepts data loss)	A failed restore means the network backup cannot be trusted (E03, E05). The disconnected copy predates the earliest known event (A7).	EXEC and BO informed. Learner message updated with new exam time expected.	Recovery source and RPO change. Exam re-run moves to Day 1.
D6	5 (min 45)	Publish a correction (exam not cancelled; status to be confirmed by 10:15). Give the journalist a holding statement only.	EXEC (drafted by COM, checked by LEG)	Rumour may drive learners to the portal. A statement on data would be speculative.	Status page, SMS and journalist reply.	Starts a media log. Reinforces a single-spokesperson rule.
D7	All (min 40)	Engage external DFIR and counsel at minute 40, brought forward from the planned 09:30 step in the playbook.	EXEC	Foothold in M365, an attacker claim and a failed backup together exceed the internal team's capacity.	Provider call. EXEC informed.	Forensic collection moves to the provider. Internal team focuses on containment and recovery.

5.4 Evaluation against the success criteria (simulated results)

Table 16. SIMULATION: evaluation. These results come from my walk-through and are my own judgement.

ID	Target	Simulated result	Assessment
SC1	Containment within 20 minutes	FS01 and FIN-PC07 isolated by minute 15. svc_backup disabled and BAK01 cut off by minute 19, because finding where the account was used took time.	Met (narrowly)
SC2	Decision within 5 minutes of each inject	Injects 1, 3, 4 and 5 were decided within 5 minutes. Inject 2 took about 8 minutes, because counsel's mobile number was not on the first contact sheet.	Partly met
SC3	No unvalidated restore	No service was reopened. The failed backup was caught before any production use.	Met
SC4	Briefing by minute 30; statements approved	The first written briefing went out at about minute 40, delayed by the minute-10 argument about reopening. External statements were all approved before release.	Partly met (briefing late)
SC5	Register entry within 10 minutes	Entries for isolation and log exports were on time. The evidence-loss note for the uncaptured FS01 memory was written at about minute 50.	Partly met
SC6	No sensitive detail by email	No sensitive detail was emailed. One near miss: the Scribe was about to email the decision log to the Executive Sponsor and was stopped.	Met (one near miss)

5.5 Improvement plan

Table 17. Improvements from the exercise. Target times are counted from the exercise date.

#	Improvement	Priority	Owner	Target completion	Measurable evidence of completion
1	Pre-draft the executive briefing template and the learner postponement notice, with pre-approved wording.	High	COM	7 days	Templates approved by EXEC and LEG. In the next drill the first briefing is issued within 15 minutes.
2	Start validation of the Friday disconnected backup at declaration, in parallel with testing the network backup, not after it fails.	High	ITO	7 days	Playbook v1.1 issued. In the next drill, validation starts by minute 15.
3	Put counsel, DFIR, provider and learner-contact sources on a printed contact card held off FS01.	High	SCR	7 days	Cards distributed to 5 holders. A call test of all numbers passes.
4	Add an evidence-loss note template and a rule to open it within 10 minutes of any skipped capture.	Medium	FOR (with SA)	14 days	Template in the playbook. Next drill: 100% of skipped captures have a note within 10 minutes.

#	Improvement	Priority	Owner	Target completion	Measurable evidence of completion
5	Write a protocol for attacker claims: verification against evidence, no engagement, preservation and counsel approval.	Medium	LEG	30 days	Protocol approved by EXEC. Next drill: decision logged within 5 minutes.
6	Add an examination continuity option (alternative venue or paper-based delivery) to the BCP, with a decision time that gives learners at least 60 minutes' notice.	Medium	BO	60 days	BCP section approved. A rehearsal shows an alternative sitting can be organised within one day.
7	Add EDR to all servers and create alerts for off-schedule privileged logons, new mail rules and OAuth consents.	High	SA	30 days	Coverage report shows 100% of servers. Test alerts fire within 10 minutes.

Post-incident review deadline and closure. For a real incident of this type, the structured blame-free review is held **within 14 days of incident closure** (ICDFA, n.d., slide 12), with a short "hot wash" within 72 hours of service return while memory is fresh. For this exercise the review meeting is held **5 working days** after the exercise. The Scribe keeps the action tracker. Owners submit the evidence in the last column of Table 17. The **IRL verifies** each item. The **Executive Sponsor closes** the action, consistent with the RACI (Table 8, closure and review, where EXEC is accountable). Open actions are reported at the monthly security meeting until all are closed, and the plan is re-issued with the changes (ICDFA, n.d., slide 13).

Task 6 – Case study analysis and critical reflection (10 marks)

Analysis of the healthcare ransomware case, slide 16 (325 words; required 300–400).

The slide 16 case describes a 2,500-employee healthcare organisation hit by a Ryuk-variant ransomware after a phishing email (ICDFA, n.d., slide 16). Three strengths stand out. First, offline backups let it recover without paying. Second, segmentation limited spread, and EDR alerts triggered immediate IR team activation. Third, a prepared team, playbooks and timely regulatory notifications supported disciplined response.

There are two limitations. Malware moved laterally for 72 hours before detection (Day 1 to Day 4), so detection was weak and the attacker had a long window to steal data. Total downtime still reached seven days. Also, "no patient data exfiltration confirmed" is not evidence of absence: the slide gives no evidence base, and it does not say when the 72-hour and seven-day clocks start.

I would transfer two changes to Northbridge. First, offline or immutable backups with scheduled restoration tests, because Northbridge's backups are neither immutable nor tested within 90 days, and E03 and E05 show how uncertain they are. Second, earlier detection through EDR on all servers plus segmentation, because Northbridge's server coverage is incomplete and FS01 encryption was noticed only when users saw files change (E06).

Restoring critical systems within 72 hours differs from seven-day full restoration. The first returns minimum essential services, which is an RTO-style target measured for priority services only. Full restoration also covers lower-priority systems, rebuilds, integrity validation and enhanced monitoring before normal operation resumes.

Before claiming no patient data was stolen, I would need evidence covering the whole dwell period: complete proxy, firewall and DNS logs showing no unexplained outbound transfers; EDR file-access telemetry; file-server audit logs; forensic review of affected hosts; and no leak-site or attacker claims. Missing or short-retention logs would block that claim, because absence of evidence is not evidence of absence.

After the tabletop, I would revise my backup decision: I would validate the Friday disconnected backup in parallel from the start, not wait for the network backup test to fail at minute 35.

Authorship and AI declaration

Authorship. This is my own individual submission. All scenario data are fictional. I am ready to explain any decision in this report if the instructor asks.

AI assistance. [REVIEW AND CONFIRM BEFORE SUBMITTING – edit so it is accurate and follows the course AI policy.] I used Claude (Anthropic) as a drafting and structuring assistant, including drafting tables and text and checking word limits and RACI rules. I reviewed, edited and take responsibility for the analysis and decisions. The legal reference

(Nigeria Data Protection Act 2023, section 40) was checked through a secondary source and should be confirmed with the official text. The simulation results in Task 5 are fictional.

References

Style: author–date (Harvard-style), used consistently. Each source is linked to the decisions it supports in the final column.

Source	Supports (decisions in this report)
ICDFA (n.d.) Incident Response Planning. GRC205 (labelled GRC105 on the slides) Incident Management and Business Continuity, Week 20 teaching deck, slides 1–18. International Cybersecurity and Digital Forensics Academy.	Four-stage structure (slide 6); incident types and ransomware severity (slide 4); preparation, tools and evidence handling (slides 7–8); detection and classification tiers (slides 9–10); containment and preserve-before-change (slide 11); lessons learned, 14-day review, documentation (slides 12–13); plan components (slide 14); RACI and roles (slide 15); healthcare case (slide 16); BCP link and exercises (slide 18). Tasks 1–6.
NIST (2025) SP 800-61 Revision 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. National Institute of Standards and Technology, April 2025. Available at: https://csrc.nist.gov/pubs/sp/800/61/r3/final	Use of CSF 2.0 alignment (Govern, Identify and Protect supporting preparation; Detect, Respond and Recover as incident response; improvement feeding all functions) in Task 2, Table 5. Not used as the source of the four-stage model.
CISA, MS-ISAC, NSA and FBI (2023) #StopRansomware Guide. Cybersecurity and Infrastructure Security Agency, September 2023. Available at: https://www.cisa.gov/stopransomware/ransomware-guide	Isolating affected systems and treating power-off as a last resort; preserving volatile evidence; out-of-band communication; scanning backups before restoration; credential resets (Task 3, Decisions 1–2 and playbook; Task 6).
Federal Republic of Nigeria (2023) Nigeria Data Protection Act 2023, section 40 (personal data breach notification).	Assumed jurisdiction and the 72-hour regulator notice and immediate data-subject notice for high-risk breaches (Task 4.3). Section references taken from the secondary source below; to be confirmed against the official text by counsel.
Afriwise (n.d.) Data breaches: compliance obligations under the Nigerian Data Protection Act 2023. Available at: https://www.afriwise.com/blog/data-breaches-compliance-obligations-under-the-nigerian-data-protection-act-2023	Secondary summary of NDPA section 40(2) and 40(3) used in Task 4.3.